

VPN Security Assessment - Executive Summary

Capture: aes128-dh2-transport-pfs-off__web_run1.pcap | Generated: 2026-09-22 12:45 UTC

HIGH RISK

Security score 30 / 100

In one sentence

The VPN uses settings that are weak by modern standards and should be changed. The encrypted traffic looks like **web browsing**.

Assessment completeness: 42%. Only this share of the security facts that matter could be established from the capture. Not determinable: IKE version, Perfect Forward Secrecy, Authentication method, SA / key lifetime.

Important: the settings below come from the VPN configuration named in the capture's file name (declared by the test setup), not from the traffic itself, because the readable part of the VPN negotiation is not in this capture. Treat the rating as "what was configured", not "what was measured".

Security settings

Setting	Value	Rating	Where the value comes from
Cipher	AES-CBC-128	MEDIUM	Declared by file name
AES-CBC-128 provides confidentiality only — it needs a separate HMAC for integrity, and mis-set integrity checking can open padding-oracle-style issues.			
DH group	Group 2 (1024-bit MODP)	WEAK	Declared by file name
1024-bit MODP is considered too small against modern computing power.			
PFS	unknown	UNKNOWN	Not determinable
Whether Perfect Forward Secrecy is enabled could not be determined from this capture.			
Mode	transport	MEDIUM	Inferred from packet sizes
Transport mode leaves the original IP header visible; only the payload is encrypted.			
Integrity	separate HMAC, tag length 16 B or 32 B	MEDIUM	Inferred from packet sizes
length mod 16 = 8 => ICV mod 16 = 0 (assumes AES-CBC with a 16-byte IV)			
Key lifetime	unknown	UNKNOWN	Not determinable
not observable in this capture (no rekey - a new SPI in the same direction - was seen)			

Replay protection	sender uses a strictly increasing sequence counter	MEDIUM	Inferred from packet sizes
all 2 SA(s) with enough packets use a strictly increasing sequence counter (no duplicates, no out-of-order packets, 0 sequence numbers never seen)			

The score is a weighted average of the rated settings (cipher 40%, key exchange 40%, forward secrecy 20%). Settings that cannot be determined are left out instead of being counted as weak. Mode is shown for information and is not scored.

Recommended actions

Priority	Action
High	Replace the weak Diffie-Hellman group. Change the key-exchange group from Group 2 (1024-bit MODP) to an elliptic-curve group (19 or 20) or MODP 3072-bit or larger.
Medium	Prefer an AEAD cipher (AES-256-GCM) over AES-CBC. Use aes256gcm16 for IKE and ESP: it protects integrity and confidentiality in one step and needs no separate HMAC.
Medium	Verify that Perfect Forward Secrecy is enabled. PFS is negotiated inside encrypted IKE messages and cannot be seen in a capture. Confirm the ESP proposal contains a DH group (for strongSwan: esp=...-ecp384!) with `ipsec statusall`.
Medium	Capture from before the tunnel comes up. Start the capture, then bring the tunnel up (for example `tcpdump -w` first, then `ipsec up`), so IKE_SA_INIT is included.
Medium	Reduce the traffic-type leak. An eavesdropper can tell this traffic is web browsing (100%). Padding packets to fixed sizes and adding dummy traffic reduces this; see the defence simulation for the effect measured on this project's dataset.
Low	Use tunnel mode unless host-to-host transport mode is required. Tunnel mode encrypts the original IP header and hides the real endpoints behind the gateways.
Low	Set and verify a short SA lifetime. Set keylife=1h and ikelifetime=4h, then verify with a capture at least twice as long as keylife so a rekey is observed.

If the recommended configuration were applied (projection, not a measurement): score now 30 (HIGH); from a new passive capture 80 (LOW); with the gateway configuration reviewed directly 100 (LOW). A capture alone cannot show forward secrecy or the authentication method, so it cannot reach 100.

What is travelling through the tunnel

Without decrypting anything, the size and timing pattern of the encrypted packets was matched against five known traffic types. Best match: **Web browsing** (model confidence 100%).

No unusual traffic patterns were flagged.

What this report cannot tell you

- An IPsec capture only shows the cipher and key-exchange group when the start of the VPN negotiation was captured. Whether forward secrecy is on is negotiated in an encrypted step and is not visible to an observer. Tunnel versus transport mode and the cipher family (CBC or GCM) can only be estimated statistically from packet sizes, and are marked "inferred" with a confidence.

- The traffic-type label is a statistical guess from packet sizes and timing, trained on five scripted traffic types. It is not proof of what users did.